

Course Name: Ethical Hacking	Code: ITA1408	CO: CO1
-------------------------------------	----------------------	----------------

SIMATS ENGINEERING

ASSESSMENT TOOL 2 – Case Study Analysis (use Google Slides)

CO1: Understand the core concepts related to malware, hardware and software vulnerabilities and their causes. (BL3)

Activity Tool : Google Slides

Assessment Tool Weightage: 5%

Marks : 20 Marks

1. **A final-year engineering student uses Nmap to scan the network of a local software company to identify open ports and running services. The student does not obtain permission from the company before performing the scan. Although no systems are compromised and no data is stolen, the company's security team detects the activity and reports it to the cybercrime cell. As a cybersecurity professional, analyze whether the student's actions are ethical and legal. Discuss the relevant provisions of the Information Technology (IT) Act, 2000, identify the possible legal consequences, and explain the correct procedure the student should have followed before conducting the security assessment.**

SOL:

Introduction

Ethical hacking is the process of identifying vulnerabilities in computer systems with the **permission of the system owner**. It helps organizations improve their security by discovering weaknesses before attackers exploit them.

Nmap is a widely used network scanning tool that identifies:

- Active devices
- Open ports
- Running services
- Operating systems

Although Nmap is a legal tool, using it without permission is considered unauthorized and may violate ethical and legal standards.

Diagram: Network Scanning Process

Student

|

Runs Nmap Scan



Company Network



Detects Open Ports & Services



Intrusion Detection System (IDS)



Security Team Alerted



Cyber Crime Cell Informed

Ethical Analysis

The student's intention was educational, but the activity was **not ethical** because:

- Permission was not obtained.
- The company was unaware of the security testing.
- Network scanning reveals important security information.
- Ethical hackers must always work within an approved scope.

Good intentions do not justify unauthorized access.

Legal Analysis (IT Act, 2000)

Section 43

Unauthorized access to a computer system or network may result in compensation for damages.

Section 66

If unauthorized access is done dishonestly or fraudulently, it becomes a punishable offence.

Section 72

If confidential information is accessed or disclosed without permission, it amounts to a breach of confidentiality.

Ethical Hacking vs Unauthorized Hacking

Ethical Hacking	Unauthorized Hacking
------------------------	-----------------------------

Permission obtained	No permission
---------------------	---------------

Legal	Illegal
-------	---------

Defined scope	No defined scope
---------------	------------------

Protects systems	May expose systems
------------------	--------------------

Reports findings	May misuse information
------------------	------------------------

Correct Procedure

Obtain Permission

|



Define Scope

|



Perform Nmap Scan



Prepare Security Report



Submit Report to Company

Preventive Measures

- Obtain written permission before testing.
- Define the scope of security assessment.
- Respect privacy and confidentiality.
- Follow responsible disclosure.
- Comply with the Information Technology Act, 2000.

Conclusion

The student used Nmap for learning purposes, but scanning another organization's network without authorization is unethical and may violate the Information Technology Act, 2000. Ethical hackers must always obtain written permission, follow responsible disclosure practices, and work within an approved scope. This approach protects both the organization and the cybersecurity professional.

2.A cybersecurity researcher discovers a SQL Injection vulnerability in a popular e-commerce website that could allow attackers to access customer information. Instead of privately informing the organization, the researcher immediately publishes the vulnerability details and proof-of-concept code on social media. Before the company can fix the issue, cybercriminals exploit the vulnerability and compromise customer data. Analyze this incident from both ethical and legal perspectives. Explain the concept of responsible vulnerability disclosure, discuss the risks of premature public disclosure, and recommend the appropriate steps the researcher should have taken.

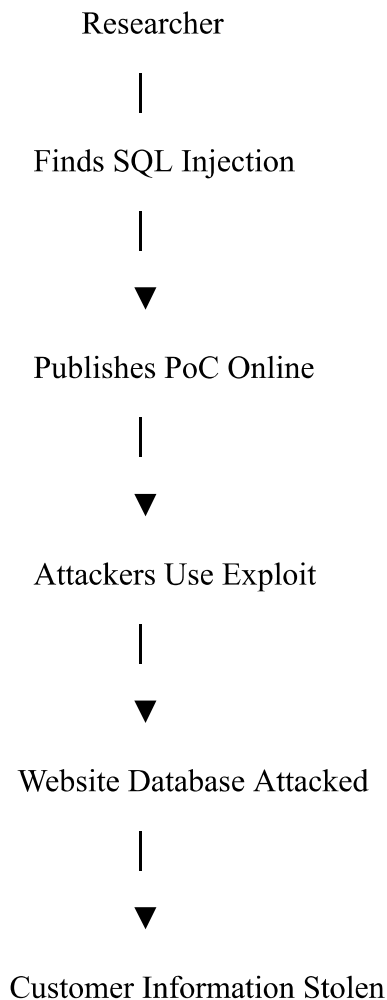
SOL:

Introduction

SQL Injection (SQLi) is one of the most dangerous web application attacks. It occurs when an attacker inserts malicious SQL commands into an application's input fields to manipulate the database. This may allow attackers to bypass authentication, steal confidential information, modify records, or even delete entire databases.

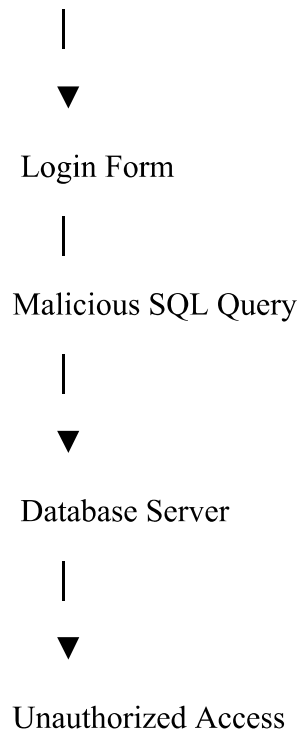
Ethical hackers and security researchers are expected to report vulnerabilities responsibly instead of making them public immediately.

Diagram: SQL Injection Attack



How SQL Injection Works

User Input



Ethical Analysis

Although the researcher intended to expose a security flaw, publishing the exploit before informing the company was **unethical**.

The researcher should have:

- Reported the vulnerability privately.
- Allowed sufficient time to fix the issue.
- Disclosed the vulnerability only after the security patch was released.

Public disclosure before patching increases the risk of cyberattacks and harms both the organization and its users.

Applicable IT Act, 2000

Section 43

Deals with unauthorized access to computer systems and databases.

Section 66

Covers computer-related offences involving dishonest or fraudulent access.

Section 72

Protects confidentiality and privacy. Unauthorized disclosure of customer information may lead to legal action.

Responsible Vulnerability Disclosure

Discover Vulnerability

|



Collect Evidence

|



Inform Organization

|



Organization Fixes Bug

|



Patch Released

|



Public Disclosure

Risks of Public Disclosure

- Theft of customer data
- Identity theft
- Financial loss
- Reputation damage

- Legal liability
- Increase in cyberattacks

Preventive Measures

Organizations should:

- Use parameterized SQL queries.
- Validate user input.
- Deploy Web Application Firewalls (WAF).
- Conduct regular security testing.
- Implement a responsible disclosure policy.

Researchers should:

- Maintain confidentiality.
- Follow responsible disclosure.
- Avoid publishing exploit code before a fix is available.

Conclusion

The researcher successfully identified a serious SQL Injection vulnerability, but publishing it publicly before informing the company was unethical and risky. Responsible Vulnerability Disclosure protects users, organizations, and researchers by allowing vulnerabilities to be fixed before attackers exploit them. Ethical hackers should always follow professional ethics and the provisions of the **Information Technology Act, 2000**.

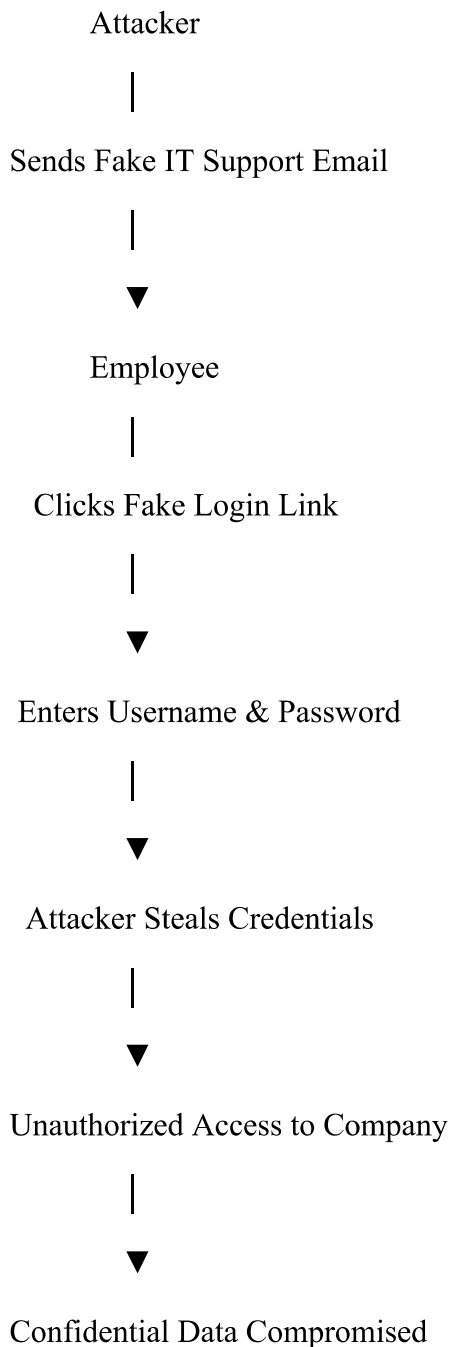
3. An employee of a financial organization receives an email that appears to be from the company's IT support team requesting immediate password verification. Believing the email to be genuine, the employee submits login credentials through the provided link. The attacker uses these credentials to gain unauthorized access to confidential company data. Examine this case and identify the type of cyberattack involved. Discuss the legal implications for the attacker under the Information Technology (IT) Act, explain the responsibilities of both the organization and the employee, and recommend effective technical and organizational measures to prevent similar attacks in the future.

SOL:

Introduction

Phishing is one of the most common **social engineering attacks** used by cybercriminals. Instead of attacking computer systems directly, attackers manipulate people into revealing sensitive information such as usernames, passwords, banking details, and OTPs. Since employees are often the weakest link in cybersecurity, phishing attacks are highly successful.

Diagram: Phishing Attack Process



How Phishing Works

Fake Email



Victim Clicks Link



Fake Login Page



Credentials Stolen



Attacker Accesses System

Ethical Analysis

The attacker intentionally impersonated the company's IT department to deceive the employee. This is unethical because it violates honesty, privacy, and trust. The attack also compromises confidential company information and may affect customers and business operations.

Employees should always verify suspicious emails before sharing sensitive information.

Applicable IT Act, 2000

Section 43

Deals with unauthorized access to computer systems.

Section 66

Covers computer-related offences involving fraudulent activities.

Section 66C – Identity Theft

Punishes unauthorized use of another person's passwords or digital identity.

Section 66D – Cheating by Personation

Punishes individuals who impersonate others using computer resources.

Section 72

Protects confidentiality and privacy of information.

Responsibilities

Employee

- Verify the sender's email address.
- Do not click suspicious links.
- Never share passwords or OTPs.
- Report suspicious emails immediately.

Organization

- Conduct cybersecurity awareness training.
- Enable Multi-Factor Authentication (MFA).
- Install spam filters and email security.
- Monitor suspicious login activities.

Preventive Measures

Employee Awareness

|



Verify Email Sender

|



Enable MFA



Report Suspicious Emails



Prevent Phishing Attack

Other security measures include:

- Strong password policies
- Regular phishing awareness training
- Secure email gateways
- Anti-virus and endpoint protection
- Periodic security audits

Impact of Phishing

On Employees

On Organization

Password theft

Data breach

Identity theft

Financial loss

Privacy loss

Reputation damage

Account compromise

Loss of customer trust

Conclusion

Phishing attacks exploit human trust rather than technical vulnerabilities. Organizations must implement technical controls such as Multi-Factor Authentication, spam filtering, and endpoint protection while regularly training employees to identify phishing emails. Following cybersecurity best practices and complying with the **Information Technology Act, 2000** helps protect sensitive information and reduce cyber threats.

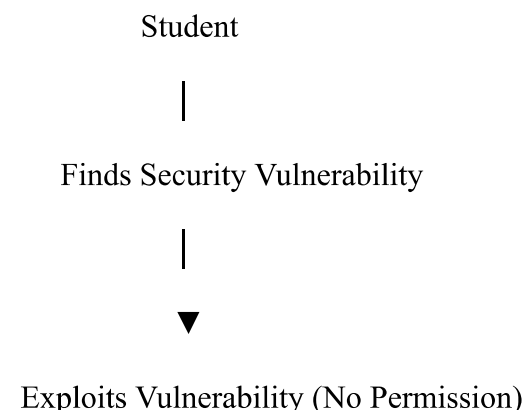
4.A cybersecurity student discovers a serious security vulnerability in the online banking portal of a private bank. The bank does not have a public bug bounty or vulnerability disclosure program. To demonstrate the severity of the issue, the student exploits the vulnerability and retrieves a small amount of customer information before reporting the findings to the bank. Although the student had no intention of causing harm, the bank initiates legal proceedings. Critically evaluate whether the student's actions are ethical and lawful. Differentiate between ethical hacking and unauthorized hacking, discuss the applicable provisions of the Information Technology (IT) Act, and explain the proper process for reporting vulnerabilities when an organization has no official disclosure policy.

SOL:

Introduction

Online banking systems store highly sensitive customer information such as account numbers, passwords, transaction history, and personal details. These systems are protected by strict cybersecurity laws and regulations. Ethical hackers help organizations identify vulnerabilities, but they must always obtain **prior written permission** before testing any system. Accessing customer information without authorization is illegal, regardless of the intention.

Diagram: Banking Website Vulnerability



|



Accesses Customer Information

|



Reports Issue to Bank

|



Bank Files Legal Complaint

Ethical Analysis

The student's intention was to improve security, but the method used was unethical because:

- No written permission was obtained.
- Customer information was accessed without authorization.
- Banking data is highly confidential.
- Ethical hacking requires permission and responsible disclosure.

Therefore, the student's actions violated the principles of ethical hacking.

Applicable IT Act, 2000

Section 43

Unauthorized access to a computer system or network may result in compensation for damages.

Section 66

Computer-related offences involving unauthorized access may lead to imprisonment or fines.

Section 72

Protects confidentiality and privacy. Accessing or revealing customer information without permission is punishable.

Ethical Hacking vs Unauthorized Hacking

Ethical Hacking	Unauthorized Hacking
Permission obtained	No permission
Legal activity	Illegal activity
Protects customer data	Accesses customer data
Reports findings responsibly	May create legal issues

Responsible Vulnerability Disclosure

Discover Vulnerability



Collect Minimum Evidence



Do Not Access Customer Data



Report to Bank Security Team



Bank Fixes Vulnerability

|



Public Disclosure (If Approved)

Preventive Measures

For Banks

- Implement Multi-Factor Authentication (MFA).
- Conduct regular penetration testing.
- Use Web Application Firewalls (WAF).
- Encrypt customer information.
- Perform regular security audits.

For Ethical Hackers

- Obtain written authorization.
- Work within the approved scope.
- Avoid accessing sensitive customer data.
- Follow responsible disclosure guidelines.

Key Learnings

- Good intentions do not justify unauthorized access.
- Ethical hacking requires prior permission.
- Banking systems contain highly sensitive information.
- Responsible disclosure protects both researchers and organizations.
- Compliance with the Information Technology Act, 2000 is essential.

Conclusion

Although the student intended to help the bank by reporting a security vulnerability, exploiting the banking website without authorization was unethical and illegal. Ethical hackers must always obtain written permission, avoid accessing confidential information, and follow responsible disclosure procedures. By complying with the **Information Technology Act, 2000** and ethical hacking principles, cybersecurity professionals can improve system security while protecting customer privacy and organizational trust.

Code of Conduct:

I G.Jaswanth Krishna(192472366) (Name / Reg. No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: G.Jaswanth Krishna